

Compliance & Secure Coding Practices in 25-26J-076

FORLENS – A LIGHTWEIGHT AI-DRIVEN ENDPOINT SECURITY SOLUTION FOR REAL-
TIME THREAT DETECTION IN SMES

Nusfa M R F – IT22908742

Sanjula E A Y – IT22340078

Salgado M. B. D – IT21289934

De Silva H S- IT22887580

Supervisor : Mr.Kanishka Yapa

Bsc (Hons) in Information Technology Specializing in Cyber Security

Department of Information Technology

Sri Lanka Institute of Information Technology

Sri Lanka

30 April 2026

1. Introduction

The ForLENS project is an integrated cybersecurity framework designed to provide real-time threat detection, automated response, secure logging, and behavioral analysis tailored for Small and Medium Enterprises (SMEs). The system combines multiple modules, including endpoint monitoring, AI-based anomaly detection, cryptographic logging, and SOAR-based automated response, into a unified architecture.

In modern cybersecurity environments, ensuring compliance and secure coding practices is essential to protect sensitive data, maintain system integrity, and meet regulatory requirements. Given that ForLENS handles system-level telemetry, behavioral data, and security logs, it is critical to implement secure coding techniques and adhere to recognized compliance standards throughout the development lifecycle. This report outlines the secure coding practices, tools, compliance measures, and challenges addressed during the development of the ForLENS system.

2. Secure Coding Standards

The development of the ForLENS framework followed established secure coding standards to ensure system security, reliability, and resilience against cyber threats. One of the primary standards adopted was the **OWASP Secure Coding Practices**, which guided the implementation of secure input handling, authentication mechanisms, and protection against common vulnerabilities such as injection attacks and improper error handling. This was particularly important in modules that process user inputs and system logs.

Additionally, principles from **ISO/IEC 27001** were incorporated to ensure that security was maintained throughout the Software Development Lifecycle (SDLC). This included implementing secure design principles, risk assessment, and continuous monitoring to maintain system integrity. The system design also aligns with best practices in secure system architecture, ensuring confidentiality, integrity, and availability of data.

Furthermore, general secure coding practices inspired by internal industry standards such as CERT (USA) guidelines were followed, including proper validation, secure memory handling, and avoiding unsafe coding constructs. These combined standards ensured that the ForLENS framework adheres to industry-recognized security practices.

3. Key Secure Coding Techniques Implemented with Examples

Several secure coding techniques were implemented across different modules of the ForLENS system to enhance overall security.

Input Validation:

All inputs, including system logs, user interactions, and network data, are validated before processing. This prevents injection attacks and ensures that only properly formatted data is handled by the system.

Error Handling:

The system implements secure error handling mechanisms where errors are logged internally without exposing sensitive information to users. This prevents attackers from gaining system-level insights through error messages.

Authentication & Authorization:

Access to system components is controlled using role-based access control mechanisms. Only authorized users can access critical system functionalities, ensuring adherence to the principle of least privilege.

Encryption:

Cryptographic techniques such as SHA-256 hashing are used to secure log data. Data in transit is protected using secure communication protocols, ensuring confidentiality and integrity.

Secure Logging:

Logs are protected using cryptographic hashing and blockchain-based anchoring, ensuring tamper-proof storage and reliable forensic analysis.

Code Access Control:

Strict access controls are applied within the system to prevent unauthorized execution of code and restrict access to sensitive components.

These techniques collectively ensure that the system is resistant to common vulnerabilities and capable of maintaining secure operations.

4. Tools & Technologies Used for Secure Coding

Several tools and technologies were used to enforce secure coding practices during the development of the ForLENS system.

Static analysis techniques were used during development to identify potential vulnerabilities in the code. Tools and manual reviews were used to detect issues such as improper input handling, insecure logic, and potential security flaws.

Additionally, penetration testing tools such as OWASP ZAP and Burp Suite were used to simulate attack scenarios and identify vulnerabilities within the system. These tools helped evaluate the system's resilience against real-world cyber threats.

Development frameworks and programming libraries were carefully selected to ensure security and reliability. Python-based libraries with strong community support and security updates were used for implementation.

Overall, the use of these tools ensured that the system was continuously tested and improved to meet secure coding requirements.

5. Compliance Standards

The ForLENS system considers several compliance standards relevant to cybersecurity and data protection.

PDPA (Personal Data Protection Act) Sri Lanka

The system ensures that personal and sensitive data is handled securely. Data collection is minimized, and only necessary information is processed. Logs are anonymized where possible, and secure storage mechanisms are used to protect user data.

Data Protection Measures:

Sensitive data is encrypted and protected using cryptographic techniques. Access to data is restricted to authorized users only.

Documentation Compliance:

Proper documentation of system processes, security measures, and data handling practices is maintained to ensure transparency and accountability.

User Consent:

Where applicable, user interactions and data collection processes are designed to ensure transparency and informed consent.

These measures ensure that the system aligns with modern data protection and cybersecurity regulations.

6. Challenges & Mitigation Strategies

Several challenges were encountered during the implementation of secure coding and compliance practices in the ForLENS project.

One of the major challenges was implementing cryptographic logging while maintaining system performance. This was addressed by using lightweight hashing techniques and selective blockchain anchoring instead of storing full logs on-chain.

Another challenge was balancing security and usability, particularly in SME environments where users may not have advanced technical knowledge. This was mitigated by implementing user-friendly interfaces and explainable outputs.

Integration of multiple security components also posed complexity challenges. This was addressed through modular system design, allowing each component to function independently while maintaining overall system integration.

Finally, ensuring compliance without overcomplicating the system required careful design decisions, focusing on essential compliance measures relevant to the project scope.

8. References

- OWASP Foundation, “OWASP Secure Coding Practices – Quick Reference Guide, v2.1,” n.d. [Online]. Available: https://owasp.org/www-project-secure-coding-practices-quick-reference-guide/assets/docs/OWASP_SCP_Quick_Reference_Guide_v21.pdf ISO/IEC 27001 Information Security Standard
- Parliament of the Democratic Socialist Republic of Sri Lanka, “Personal Data Protection Act, No. 9 of 2022,” Gazette of the Democratic Socialist Republic of Sri Lanka, certified Mar. 19, 2022. [Online]. Available: <https://www.documents.gov.lk>. [Accessed: 05-May-2026].
- J. W. Moore and R. C. Seacord, “Secure Coding Standards,” Crosstalk: The Journal of Defense Software Engineering, Software Technology Support Center (STSC), U.S. Air Force, pp. 9–16, Mar. 2007. [Online]. Available: <https://www.stsc.hill.af.mil>. [Accessed: 05-May-2026].